HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Implementation Solution Guide

Version 1.0.0 · 2026-06-27

Contents

Executive Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 4

- The problem . . . 4
- The solution . . . 4
- What is included . . . 4
- Important boundary . . . 4
- Business value . . . 5
- Audience . . . 5

1. Solution Overview — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 5

- Description . . . 5
- Why this matters . . . 6
- Scope . . . 6
- Outcomes . . . 6
- Audience . . . 7

2. Requirements — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 7

- R1 — Microsoft Intune licensing and MDM authority . . . 7
- R2 — Microsoft Entra ID P1 (for Conditional Access) . . . 7
- R3 — Microsoft Defender for Endpoint + Defender Vulnerability Management . . . 8
- R4 — Defender for Endpoint onboarding of clinical endpoints . . . 8
- R5 — The clinical endpoint group `HIPAA – Clinical Endpoints` . . . 8
- R6 — BitLocker-capable devices (TPM) . . . 9
- R7 — Patch / update currency mechanism . . . 9
- R8 — Conditional Access readiness (break-glass + report-only) . . . 9
- R9 — Control mapping document and evidence ownership . . . 9
- R10 — Named control owner / accountable role . . . 10
- R11 — Evidence store / repository . . . 10
- R12 — Change control and exception process . . . 10

3. Implementation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 11

- Phase 1 — Assess: map controls to enforceable settings . . . 11
- Phase 2 — Configure: compliance policy and configuration baselines . . . 13
- Phase 3 — Gate: Conditional Access on compliance . . . 15
- Phase 4 — Remediate: Defender Vulnerability Management workflow . . . 16
- Phase 5 — Evidence / Report: produce audit-ready output . . . 17

Phase 6 — Operate: run the control set over time . . . 17
5. Testing & Validation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 18
Gate 1 — Tenant readiness (Assess/Configure prerequisites) . . . 18
Gate 2 — Devices evaluate Compliant . . . 18
Gate 3 — Conditional Access blocks non-compliant devices . . . 18
Gate 4 — Key safeguards enforced . . . 18
Gate 5 — TVM exposure reduced . . . 19
Gate 6 — Evidence produced and retained . . . 19
Regression / ongoing validation . . . 19
6. Troubleshooting — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 20
Compliance evaluation . . . 20
BitLocker / encryption . . . 20
Automatic lock / antivirus / firewall . . . 21
Conditional Access (the gate) . . . 21
Defender Vulnerability Management . . . 21
Evidence / reporting . . . 22
Discovery / drift . . . 22
7. Best Practices — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 22
Naming and traceability . . . 23
Compliance policy design . . . 23
Conditional Access (the gate) . . . 23
Vulnerability management (Defender TVM) . . . 23
Evidence and audit readiness . . . 24
Operations and change control . . . 24
Least privilege and identity hygiene . . . 24
8. Deliverables Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) 24
Documentation . . . 25
Scripts (PowerShell, Microsoft Graph where applicable) . . . 25
Visual asset . . . 26
How the deliverables fit together . . . 26
Appendix A — PowerShell Scripts 28

Executive Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

The problem

Healthcare and other regulated organizations can *write* an endpoint security policy but rarely *enforce* it on every device or *prove* it on demand. Both a HIPAA audit (or an OCR investigation after a breach) and a HITRUST assessment turn on one question: show that the safeguard was configured, applied to the in-scope devices, and operating during the review period. A single unencrypted, unlocked, out-of-date, or vulnerable clinical laptop is exactly the exposure that turns a lost device into a reportable breach — and missing evidence turns a controllable finding into an expensive one.

The solution

This solution converts the technical safeguards of the **HIPAA Security Rule** and the control expectations of the **HITRUST CSF** into enforceable, auditable controls on clinical Windows endpoints using **Microsoft Intune** and **Microsoft Defender for Endpoint**. It delivers a repeatable six-phase model — **Assess** (map controls to settings) → **Configure** (compliance policies + configuration baselines) → **Gate** (Conditional Access on compliance) → **Remediate** (Defender Vulnerability Management) → **Evidence/Report** (audit-ready output) → **Operate** — with every object named consistently and traceable from control to enforcement to evidence.

Concretely, it enforces and proves: BitLocker encryption, automatic screen lock, Microsoft Defender Antivirus health and signature currency, Windows Firewall, patch currency, and account/sign-in controls; blocks non-compliant clinical endpoints from corporate resources via a Conditional Access gate; drives down vulnerability exposure through a governed Defender remediation and exception workflow; and emits dated, audit-ready evidence into a retained, access-controlled repository.

What is included

- A **control-to-policy mapping** tying each in-scope HIPAA/HITRUST safeguard to a named Microsoft object and an accountable owner.
- Named **Intune compliance policy** and **configuration baselines** that measure and enforce the endpoint safeguards.
- A named **Conditional Access gate** requiring device compliance before access.
- A **Defender Vulnerability Management** remediation workflow with exception handling and exposure-trend reporting.
- Five **PowerShell tools** (Microsoft Graph) for discovery, per-device validation, evidence reporting, safe remediation, and baseline scaffolding — all read-only by default.

Important boundary

HIPAA and HITRUST are **frameworks**, not products. This solution provides the **technical enforcement and evidence layer** that supports a compliance program; it does **not** by itself make an organization HIPAA compliant or confer HITRUST certification, which require organizational policy, risk analysis,

workforce training, business associate agreements, physical safeguards, and authorized third-party assessment. **Microsoft Purview Compliance Manager** is referenced as an optional assessment aid.

Business value

- **Audit readiness:** trace any control to its enforcement and to dated evidence in seconds.
- **Breach-risk reduction:** encrypted, locked, protected, patched endpoints — and a gate that keeps non-compliant devices out of ePHI.
- **Measurable exposure reduction:** a governed vulnerability workflow with trend evidence over time.
- **Repeatable and portable:** a named, documented pattern an internal team or MSP can deploy across clinical sites — and reuse for any regulated environment.

Audience

Healthcare IT and security administrators, virtual CISOs and compliance leads, and MSPs delivering managed compliance — and any regulated organization that must enforce and evidence endpoint security controls.

1. Solution Overview — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Description

This solution maps the technical safeguards of the **HIPAA Security Rule** (45 CFR Part 164, Subpart C) and the control expectations of the **HITRUST CSF** to enforceable, auditable controls on clinical Windows endpoints using **Microsoft Intune** (device compliance + configuration baselines) and **Microsoft Defender for Endpoint** (Defender Vulnerability Management). It then operationalizes the loop that auditors actually ask for: enforce the control, gate access on it with **Conditional Access**, remediate the vulnerabilities the enforcement surfaces, and **produce evidence** that proves it.

The solution delivers a repeatable phase model — **Assess** (map controls to settings) → **Configure** (compliance policies + configuration baselines) → **Gate** (Conditional Access on compliance) → **Remediate** (Defender TVM exposure reduction) → **Evidence/Report** (audit-ready output) → **Operate** (ongoing review) — together with five PowerShell tools (Microsoft Graph) for discovery, per-device validation, reporting, safe remediation, and baseline scaffolding.

> ***Important — what this is and is not.*** *HIPAA and HITRUST are **frameworks**, not products. This solution provides the **technical enforcement and evidence layer** that supports a compliance program; it does **not** by itself make an organization "HIPAA compliant" or confer any HITRUST certification. Legal compliance and certification require organizational policies, risk analysis, workforce training, business associate agreements, physical safeguards, and (for HITRUST) a formal assessment by an authorized External Assessor. Treat this solution as the part a Microsoft administrator can build and prove — the device-level safeguards and the evidence that they are operating.*

Why this matters

Most healthcare organizations can *state* a security policy ("all devices that access ePHI must be encrypted, lock automatically, run antivirus, and stay patched") but cannot *enforce* it on every endpoint or *prove* it on demand. A HIPAA audit (or an OCR investigation after a breach) and a HITRUST assessment both turn on the same question: show me that the safeguard was configured, applied to the in-scope devices, and operating during the period under review. A laptop that is unencrypted, has a disabled screen lock, an out-of-date Defender engine, or a known critical vulnerability is exactly the exposure that turns a lost device into a reportable breach.

This solution closes that gap. It converts framework language into named Intune and Defender objects, blocks non-compliant clinical endpoints from reaching corporate resources, drives down vulnerability exposure, and emits the evidence — compliance state per device, configuration proof, and TVM exposure trend — that an assessor will accept.

Scope

In scope

- Mapping HIPAA Security Rule technical safeguards and HITRUST CSF control expectations to specific, enforceable Intune and Defender settings.
- **Intune device compliance policies** for clinical Windows endpoints: BitLocker encryption, screen lock / inactivity timeout, antivirus (Microsoft Defender Antivirus) healthy + signatures current, firewall enabled, minimum OS build / patch currency, and account/sign-in controls.
- **Intune configuration baselines** (settings catalog / security baselines) that *enforce* the safeguards the compliance policy *measures*.
- A **Conditional Access** gate that requires device compliance before access to corporate cloud resources is granted.
- **Microsoft Defender Vulnerability Management (TVM)**: exposure scoring, security recommendations, and a remediation workflow with exception handling.
- **Evidence and reporting**: audit-ready exports of compliance state, configuration proof, and exposure/remediation trend.

Out of scope

- Legal interpretation of HIPAA/HITRUST applicability, risk analysis methodology, or any compliance attestation/certification.
- macOS, iOS/iPadOS, Android, and Linux endpoints (the named objects target Windows clinical endpoints; the pattern is extensible).
- Server, EHR-application, network, and physical safeguards beyond the endpoint.
- Data loss prevention, email/collaboration controls, and identity governance beyond the Conditional Access compliance gate.

Outcomes

After implementing this solution you will have:

1. A documented **control-to-policy mapping** linking each in-scope HIPAA/HITRUST safeguard to a named Intune/Defender object and a named control owner.

2. Clinical Windows endpoints evaluating **Compliant** against an enforced baseline (encryption, lock, AV, firewall, patch, access).

3. A **Conditional Access** gate that blocks non-compliant clinical endpoints from corporate resources.

4. A running **Defender TVM remediation workflow** with measurable exposure reduction and a documented exception process.

5. **Audit-ready evidence** produced on a schedule — per-device compliance, configuration proof, and exposure/remediation trend — stored in a defined evidence repository.

Audience

Healthcare IT and security administrators, virtual CISOs and compliance leads, and MSPs delivering managed compliance for regulated clients. The pattern applies to any regulated organization (finance, legal, government contracting) that must enforce and evidence endpoint security controls — not healthcare alone.

2. Requirements — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Each requirement follows the house pattern: **Description / Why / Verify / Implement-if-missing**. Never assume a prerequisite is already in place — verify it, and provision it if it is not.

R1 — Microsoft Intune licensing and MDM authority

• **Description:** A Microsoft Intune plan (Intune Plan 1, included in Microsoft 365 E3/E5, Business Premium, or equivalent) with Intune set as the MDM authority.

• **Why:** Device compliance policies and configuration baselines are Intune features; without an Intune license assigned to the operators and enrolling users, no policy can be authored or applied.

• **Verify:** Sign in to the **Microsoft Intune admin center** (`https://intune.microsoft.com`) > **Tenant administration** > **Tenant status** and confirm the tenant is active. Check **Users** > (a pilot user) > **Licenses** for an Intune-bearing SKU.

• **Implement if missing:** Acquire Intune licensing (or a bundle that includes it) in the **Microsoft 365 admin center** > **Billing** > **Purchase services**, then assign licenses to operators and to the clinical endpoint users.

R2 — Microsoft Entra ID P1 (for Conditional Access)

• **Description:** Microsoft Entra ID P1 (or P2 / a bundle that includes it) for every user whose access will be gated.

• **Why:** The compliance gate in this solution is a **Conditional Access** policy, which requires Entra ID P1. Without it, you can measure compliance but cannot *enforce* it at sign-in.

• **Verify: Microsoft Entra admin center** (`https://entra.microsoft.com`) > **Identity** > **Overview** > **Licenses**; and confirm Conditional Access is available under **Protection** > **Conditional Access**.

• **Implement if missing:** Acquire Entra ID P1 (or M365 E3/E5/Business Premium, which include it) and assign it to the gated population.

R3 — Microsoft Defender for Endpoint + Defender Vulnerability Management

• **Description:** Microsoft Defender for Endpoint (Plan 2, e.g. via M365 E5 / E5 Security) which includes **Defender Vulnerability Management (TVM)** core capabilities; or the **Defender Vulnerability Management add-on** for premium capabilities.

• **Why:** The remediation phase relies on Defender TVM exposure scoring, security recommendations, and the remediation/exception workflow. These are not available without Defender for Endpoint onboarding and entitlement.

• **Verify: Microsoft Defender portal** (`https://security.microsoft.com`) > **Settings** > **Endpoints** > **Licenses**; and confirm **Vulnerability management** appears in the left navigation.

• **Implement if missing:** Acquire Defender for Endpoint P2 (or E5 Security) and, if premium TVM features are needed, the **Defender Vulnerability Management** add-on.

R4 — Defender for Endpoint onboarding of clinical endpoints

• **Description:** Clinical Windows endpoints onboarded to Defender for Endpoint so they report sensor data and TVM exposure.

• **Why:** A device that is not onboarded contributes no vulnerability data and cannot be remediated through TVM; it is invisible to the exposure score.

• **Verify: Defender portal** > **Assets** > **Devices** and confirm the clinical endpoints are listed with **Onboarding status = Onboarded** and **Sensor health = Active**.

• **Implement if missing:** In **Intune admin center** > **Endpoint security** > **Microsoft Defender for Endpoint**, enable the connector and turn on **Allow Microsoft Defender for Endpoint to enforce Endpoint Security Configurations**; deploy the onboarding configuration to the clinical endpoint group (R5).

R5 — The clinical endpoint group `HIPAA – Clinical Endpoints`

• **Description:** A Microsoft Entra security group named `HIPAA – Clinical Endpoints` containing every Windows device in scope for HIPAA/HITRUST endpoint enforcement (dynamic membership preferred).

• **Why:** Every policy, baseline, onboarding profile, and the Conditional Access gate target this single named group. A consistent, accurate scope is the difference between "all clinical devices are enforced" and a silent gap. Use one group, named verbatim, so assignment is unambiguous and auditable.

• **Verify: Entra admin center** > **Groups** > search `HIPAA – Clinical Endpoints`; confirm it exists, its membership rule, and that expected devices are members.

• **Implement if missing: Entra admin center** > **Groups** > **New group** > Type **Security**, Name `HIPAA – Clinical Endpoints`. For dynamic device membership use a rule such as `(device.deviceOSType -eq "Windows") and (device.deviceCategory -eq`

`"Clinical"`) (or a naming-convention rule that matches your asset standard). Document the rule with the control owner (R10).

R6 — BitLocker-capable devices (TPM)

• **Description:** Clinical endpoints with a TPM (1.2/2.0) and UEFI firmware capable of BitLocker full-disk encryption.

• **Why:** Encryption-at-rest is the single most leveraged HIPAA technical safeguard for lost/stolen devices (it is an addressable specification and the practical basis for the breach-notification safe harbor). If hardware cannot do BitLocker, the encryption control cannot be enforced.

• **Verify:** On a sample device run `manage-bde -status` (look for a usable TPM and encryptable volume), or check **Intune admin center** > **Devices** > (device) > **Hardware** for TPM presence; review **Endpoint security** > **Disk encryption** reporting.

• **Implement if missing:** Enable/clear the TPM and enable UEFI Secure Boot in firmware; replace hardware that lacks a TPM. Then deploy the BitLocker configuration in the configuration baseline (see implementation).

R7 — Patch / update currency mechanism

• **Description:** A managed update mechanism — **Windows Update for Business** rings (Intune) or equivalent — keeping clinical endpoints on a supported, current build.

• **Why:** The compliance policy measures minimum OS build / patch currency; without a managed update flow, devices drift out of compliance and accumulate TVM vulnerabilities that cannot be closed by patching.

• **Verify: Intune admin center** > **Devices** > **Windows** > **Update rings for Windows 10 and later** (or **Feature/Quality update policies**) and confirm a ring targets `HIPAA – Clinical Endpoints`.

• **Implement if missing:** Create an **Update ring** assigned to `HIPAA – Clinical Endpoints` with appropriate deferral/deadline settings, and verify devices report a current build.

R8 — Conditional Access readiness (break-glass + report-only)

• **Description:** A break-glass (emergency access) account excluded from all Conditional Access, and the ability to deploy a policy in **Report-only** mode first.

• **Why:** A compliance gate that blocks non-compliant devices can lock out administrators if misconfigured. A break-glass account and a report-only rollout prevent a self-inflicted outage and let you measure impact before enforcing.

• **Verify: Entra admin center** > **Protection** > **Conditional Access** — confirm a cloud-only break-glass account exists and is excluded from policies; confirm report-only mode is available.

• **Implement if missing:** Create a cloud-only emergency access account with a long, stored credential, exclude it from all CA policies, and monitor its sign-ins. Plan to roll the gate out in **Report-only** before **On**.

R9 — Control mapping document and evidence ownership

• **Description:** A maintained mapping that ties each in-scope HIPAA Security Rule safeguard and HITRUST CSF control to the named Intune/Defender object that enforces it and the named owner accountable for it.

• **Why:** Assessors do not accept "Intune is configured" — they trace a specific control to a specific enforcement and an accountable owner. The mapping is the spine of the audit narrative and is referenced by every later phase.

• **Verify:** Confirm a current mapping artifact exists (the implementation produces the structure) and that each row names a safeguard, an enforcing object, an evidence source, and an owner.

• **Implement if missing:** Build the mapping in the Assess phase of the implementation; store it in the evidence repository (R11) and review it at each change (R12).

R10 — Named control owner / accountable role

• **Description:** A designated owner (security/compliance lead) accountable for the endpoint control set, exceptions, and evidence.

• **Why:** HIPAA requires assigned security responsibility; HITRUST control maturity is graded partly on defined accountability. Unowned controls drift and exceptions accumulate silently.

• **Verify:** Confirm the owner is named in the control mapping (R9) and that exception approvals route to that role.

• **Implement if missing:** Assign the role formally, record it in the mapping, and route the exception and change processes (R12) through it.

R11 — Evidence store / repository

• **Description:** A defined, access-controlled location to retain generated evidence (compliance exports, configuration proof, TVM exposure/remediation reports) for the required retention period.

• **Why:** Evidence that is not retained cannot be produced for an audit covering a past period. HIPAA documentation retention is six years; HITRUST assessments review a defined look-back window.

• **Verify:** Confirm a repository exists (e.g. a restricted SharePoint/document library or secured file share) with access limited to the owner and assessors, and a retention setting applied.

• **Implement if missing:** Provision a restricted repository, apply retention, and point the reporting script output (`HIPAACOMP-Report.ps1`) at it.

R12 — Change control and exception process

• **Description:** A lightweight change-control and exception process for the compliance baseline, the CA gate, and TVM remediation deferrals.

• **Why:** Auditors expect that control changes and risk-accepted exceptions are reviewed, approved by the owner, time-bound, and documented — not made ad hoc.

• **Verify:** Confirm a process exists for proposing/approving changes to the named objects and for recording TVM exceptions with justification, approver, and expiry.

• **Implement if missing:** Adopt a simple approval workflow (ticket or change record) gated by the owner (R10); record exceptions in Defender TVM with a documented business justification and review date, mirrored in the evidence store.

See `source/global-requirements-healthcare-solutions.md` for category-wide requirements common to all Healthcare Solutions (tenant, roles, network, data-handling). The requirements above are specific to this solution.

3. Implementation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

This implementation follows the phase model **Assess** → **Configure** → **Gate** → **Remediate** → **Evidence/Report** → **Operate**. Every object is **named verbatim** using the `<Purpose> – <Scope> – <Stage>` convention and reused across phases, scripts, and evidence. Reuse the exact names. Full navigation paths are given for every step; never assume a prerequisite — if a referenced object does not exist, build it per `02-requirements.md` first.

***Reminder:** This builds the technical enforcement and evidence layer. It does not constitute HIPAA compliance or HITRUST certification on its own.*

Phase 1 — Assess: map controls to enforceable settings

Step 1 — Confirm the scope group exists

1. Open the **Microsoft Entra admin center** (`https://entra.microsoft.com`) > **Identity** > **Groups** > **All groups**.

2. Search for `HIPAA – Clinical Endpoints`. Confirm it exists, is a **Security** group, and its (preferably dynamic) device membership rule resolves the in-scope clinical Windows endpoints.

3. If it does not exist, create it per `02-requirements.md` R5 before proceeding. Every object below targets this group.

Step 2 — Build the control-to-policy mapping

Create the mapping artifact that ties each in-scope safeguard to the object that will enforce it, the evidence source, and the owner. Store it in the evidence repository (R11). Use this structure (the named objects are created in later phases):

HIPAA Security Rule safeguard	HITRUST CSF area	Enforcing object (named)	Evidence source	Owner
Encryption & decryption — §164.312(a)(2)(iv)	06 Configuration / 19 Data Protection	`Encryption – Clinical Endpoints – Baseline` (BitLocker)	Intune disk-encryption report; `HIPAACOMP-Report.ps1`	(R10)

HIPAA Security Rule safeguard	HITRUST CSF area	Enforcing object (named)	Evidence source	Owner
Automatic logoff — §164.312(a)(2)(iii)	01 Access Control	`Lock – Clinical Endpoints – Baseline` (inactivity lock/timeout)	Compliance + config report	(R10)
Protection from malicious software — §164.308(a)(5)(ii)(B)	09 Endpoint Protection	`Antivirus – Clinical Endpoints – Baseline` (Defender AV)	Defender AV health; compliance report	(R10)
Integrity / network safeguards — §164.312(c)(1)	09 Network Protection	`Firewall – Clinical Endpoints – Baseline` (Windows Firewall)	Config report	(R10)
Security updates / patch — §164.308(a)(1)(ii)(B)	10 Vulnerability Mgmt	`Patch – Clinical Endpoints – Baseline` (min OS build) + Update ring	Compliance report; Defender TVM	(R10)
Access control / unique user ID — §164.312(a)(2)(i)	01 Access Control	`Access – Clinical Endpoints – Baseline` (account/sign-in controls)	Config report	(R10)
Vulnerability exposure management	10 Vulnerability Mgmt	Defender TVM + `Vulnerability – Clinical Endpoints – Remediation`	Defender exposure score; `HIPAACOMP-Report.ps1`	(R10)
Access enforcement at sign-in	01 Access Control	`Require Compliance – Clinical Endpoints – Gate` (Conditional Access)	CA sign-in logs	(R10)

The mapping is the audit spine. Each later step names the object referenced in this table; keep the table current as objects are created and renamed.

Phase 2 — Configure: compliance policy and configuration baselines

The **compliance policy measures** the safeguards; the **configuration baselines enforce** them. Build both.

Step 3 — Create the compliance policy `HIPAA Compliance – Clinical Endpoints – Policy`

1. Open the **Microsoft Intune admin center** (`https://intune.microsoft.com`) > **Devices** > **Compliance** > **Compliance policies** > **+ Create policy**.

2. **Platform:** *Windows 10 and later*. Click **Create**.

3. **Basics:** Name = `HIPAA Compliance – Clinical Endpoints – Policy`; Description = "Measures HIPAA/HITRUST endpoint safeguards: BitLocker, lock, Defender AV, firewall, patch currency, sign-in. Targets HIPAA – Clinical Endpoints." Click **Next**.

4. **Compliance settings** — expand each section and set:

• **Device Health:** *Require BitLocker* = **Require**; *Require Secure Boot to be enabled* = **Require**; *Require code integrity* = **Require**.

• **Device Properties:** *Minimum OS version* = your current supported Windows build (drives patch currency; update this value as builds advance — see R7).

• **System Security:**

• *Require a password to unlock mobile devices* = **Require**; *Maximum minutes of inactivity before password is required* = **15** (automatic logoff / screen lock).

• *Encryption of data storage on device* = **Require**.

• *Firewall* = **Require**.

• *Antivirus* = **Require**; *Antispyware* = **Require**.

• *Microsoft Defender Antimalware* = **Require**; *Defender Antimalware minimum version* = (a recent platform version); *Real-time protection* = **Require**.

• *Microsoft Defender Antimalware security intelligence up-to-date* = **Require** (signatures current).

• **Microsoft Defender for Endpoint:** *Require the device to be at or under the machine risk score* = **Medium** (gates on Defender's device risk; requires the Defender connector, R4).

1. **Actions for noncompliance:** keep *Mark device noncompliant* = **Immediately**; add *Send email to end user* (a customized notification) and *Remotely lock the noncompliant device* if appropriate. Click **Next**.

2. **Scope tags:** apply your scope tag if used. Click **Next**.

3. **Assignments: Included groups** > add `HIPAA – Clinical Endpoints`. Click **Next** > **Create**.

__Verify: Devices__ > __Compliance__ > open the policy > __Device status__ — devices should begin reporting within an evaluation cycle.

Step 4 — Create the configuration baseline `Encryption – Clinical Endpoints – Baseline` *(BitLocker)*

1. **Intune admin center** > **Endpoint security** > **Disk encryption** > **+ Create policy**.

2. **Platform** = *Windows 10 and later*; **Profile** = *BitLocker*. Click **Create**.

3. **Basics:** Name = `Encryption – Clinical Endpoints – Baseline`; Description = "Enforces BitLocker silent encryption for clinical endpoints (HIPAA encryption safeguard)."

4. **Configuration settings:**

• *Enable full disk encryption for OS and fixed data drives* = **Yes**.

• *Require storage cards to be encrypted (mobile only)* as applicable.

• **BitLocker – Base Settings:** *Enable storage card encryption* / *Warning for other disk encryption* = **No**; *Allow standard users to enable encryption during Autopilot* = **Yes**; *Configure client-driven recovery password rotation* = **Enabled for Azure AD-joined devices**.

• **BitLocker – OS Drive Settings:** *Startup authentication required* = **Yes**; *Compatible TPM startup* = **Required**; *Recovery options* > *Save BitLocker recovery information to Azure AD* = **Yes**; *Store recovery information before enabling* = **Yes**.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

***Verify: Endpoint security** > **Disk encryption** > the policy > device/encryption status; and **Devices** > (device) > **Recovery keys** shows escrowed keys.*

Step 5 — Create the configuration baseline `Lock – Clinical Endpoints – Baseline` *(automatic logoff)*

1. **Intune admin center** > **Devices** > **Configuration** > **+ Create** > **New policy**.

2. **Platform** = *Windows 10 and later*; **Profile type** = *Settings catalog*. Click **Create**.

3. **Basics:** Name = `Lock – Clinical Endpoints – Baseline`; Description = "Enforces automatic screen lock / inactivity timeout (HIPAA automatic logoff)."

4. **Configuration settings** > **+ Add settings** > search **Device Lock** and add:

• *Maximum Inactivity Time Lock Screen* = **15** (minutes).

• *Allow Screen Timeout While Locked User Config* and machine inactivity limit (Local Policies Security Options > *Interactive logon: Machine inactivity limit*) = **900** seconds.

• *Require password when device returns from idle* = **Enabled**.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

Step 6 — Create the configuration baseline `Antivirus – Clinical Endpoints – Baseline` *(Defender AV)*

1. **Intune admin center** > **Endpoint security** > **Antivirus** > **+ Create policy**.

2. **Platform** = *Windows 10, Windows 11, and Windows Server*; **Profile** = *Microsoft Defender Antivirus*. **Create**.

3. **Basics:** Name = `Antivirus – Clinical Endpoints – Baseline`; Description = "Enforces Microsoft Defender Antivirus real-time protection, cloud protection, and signature currency (HIPAA malware protection)."

4. **Configuration settings:** *Allow Realtime Monitoring* = **Allowed**; *Allow Cloud Protection* = **Allowed**; *Cloud Block Level* = **High**; *Allow Behavior Monitoring* = **Allowed**; *Submit Samples Consent* = **Send safe samples automatically**; *Signature Update Interval* = **4** (hours); *Allow Scanning Network Files* = **Allowed**; *Schedule a scan* (quick daily).

5. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

Step 7 — Create the configuration baseline `Firewall – Clinical Endpoints – Baseline`

1. **Intune admin center** > **Endpoint security** > **Firewall** > **+ Create policy**.

2. **Platform** = *Windows 10, Windows 11, and Windows Server*; **Profile** = *Microsoft Defender Firewall*. **Create**.

3. **Basics:** Name = `Firewall – Clinical Endpoints – Baseline`; Description = "Enforces Windows Defender Firewall on all profiles (HIPAA network safeguard)."

4. **Configuration settings:** for **Domain**, **Private**, and **Public** profiles set *Enable Firewall* = **True**; *Inbound connections blocked* = **True** (default); *Outbound connections required* = **Allowed**; *Notify on inbound block* as desired.

5. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

Step 8 — Create the configuration baselines `Patch – Clinical Endpoints – Baseline` *and* `Access – Clinical Endpoints – Baseline`

1. **Patch:** Confirm an **Update ring for Windows 10 and later** (R7) targets `HIPAA – Clinical Endpoints` with sensible quality/feature deferral and deadlines, named `Patch – Clinical Endpoints – Baseline` (rename the ring to match). Path: **Devices** > **Windows** > **Update rings for Windows 10 and later**.

2. **Access: Devices** > **Configuration** > **+ Create** > **New policy** > *Windows 10 and later* > *Settings catalog*. Name = `Access – Clinical Endpoints – Baseline`; Description = "Enforces account/sign-in controls (HIPAA access control / unique user ID)." Add settings: *Limit Local Account Use Of Blank Passwords To Console Logon Only* = **Enabled**; *Account Lockout Threshold* = **10**; *Minimum Password Length* per policy; *Interactive logon: Do not display last signed-in* = **Enabled**; disable built-in Guest. **Assign** to `HIPAA – Clinical Endpoints`. **Create**.

*Optionally apply a Microsoft **Security baseline** (Endpoint security > Security baselines > *Security Baseline for Windows*) to `HIPAA – Clinical Endpoints` for breadth, after reconciling any conflicts with the targeted baselines above.*

Phase 3 — Gate: Conditional Access on compliance

Step 9 — Create the Conditional Access gate `Require Compliance – Clinical Endpoints – Gate`

1. Open the **Microsoft Entra admin center** > **Protection** > **Conditional Access** > **Policies** > **+ New policy**.

2. **Name:** `Require Compliance – Clinical Endpoints – Gate`.

3. **Users:** Include the gated population (e.g. clinical staff group); **Exclude** the break-glass account (R8) and any service accounts.

4. **Target resources:** *Cloud apps* > **All cloud apps** (or scope to the resources holding ePHI, e.g. SharePoint/Exchange/EHR SAML app).

5. **Conditions:** *Device platforms* = **Windows** (to scope to clinical Windows endpoints; pair with device filters if needed).

6. **Grant:** *Grant access* > check **Require device to be marked as compliant** (and, if desired, **Require Microsoft Entra hybrid joined device**). Set **Require all the selected controls**.

7. **Enable policy:** set to **Report-only** first. Click **Create**.

8. After validating impact in report-only (see `05-testing.md`), edit the policy and set **Enable policy** = **On**.

Verify: *A non-compliant clinical Windows device is blocked from the target resource; a compliant one is allowed. Review* ***Entra*** *>* ***Monitoring*** *>* ***Sign-in logs*** *>* ***Conditional Access*** *tab.*

Phase 4 — Remediate: Defender Vulnerability Management workflow

Step 10 — Establish exposure baseline in Defender TVM

1. Open the **Microsoft Defender portal** (`https://security.microsoft.com`) > **Vulnerability management** > **Dashboard**.

2. Record the current **Exposure score** and **Microsoft Secure Score for Devices** as the baseline (store in the evidence repository, R11).

3. Filter the dashboard by the device group corresponding to `HIPAA – Clinical Endpoints` (create/confirm a matching **device group** under **Settings** > **Endpoints** > **Device groups** if Defender RBAC device groups are used).

Step 11 — Triage and drive `Vulnerability – Clinical Endpoints – Remediation`

1. **Vulnerability management** > **Recommendations**. Sort by impact/exposure for the clinical device group.

2. For each top recommendation (e.g. update an out-of-date application, enable a hardening setting), open it and review **Exposed devices** and **Remediation options**.

3. Click **Request remediation** to create a remediation task named `Vulnerability – Clinical Endpoints – Remediation` (use this name as the task title prefix). Assign it to the owner (R10) / IT team via the integrated **Microsoft Intune** remediation request (if connected) or as a tracked task; set a due date.

4. Track open tasks under **Vulnerability management** > **Remediation**. Patch-type recommendations are closed by the Update ring (`Patch – Clinical Endpoints – Baseline`); configuration-type recommendations are closed by the corresponding baseline.

Step 12 — Handle exceptions

1. For a recommendation that cannot be remediated now (clinical/medical-device dependency, vendor constraint), open it > **Exception options** > **Create exception**.

2. Choose **justification** (e.g. *Third-party control*, *Risk accepted*, *Planned remediation*) and **scope** (device group or global), and set an **expiry**.

3. Record the exception (justification, approver = R10, expiry) in the evidence repository per the change/exception process (R12). Review exceptions at expiry.

Phase 5 — Evidence / Report: produce audit-ready output

Step 13 — Capture compliance and configuration evidence

1. **Intune admin center** > **Devices** > **Compliance** > `HIPAA Compliance – Clinical Endpoints – Policy` > **Device status** / **Per-setting status** — export.

2. **Reports** > **Device compliance** > run **Device compliance** and **Noncompliant devices** reports; export to the evidence store (R11).

3. **Endpoint security** > **Disk encryption** — export BitLocker/encryption status as encryption proof.

4. Run `HIPAACOMP-Report.ps1` (Microsoft Graph) to generate a consolidated CSV: per-device compliance state, key safeguard status, and Defender TVM exposure — written to the evidence repository.

Step 14 — Capture vulnerability/remediation evidence

1. **Defender portal** > **Vulnerability management** > **Dashboard** — export exposure score and trend; **Recommendations** and **Remediation** — export open/closed task status and exceptions.

2. Compare current exposure to the Step 10 baseline to demonstrate reduction over the period. Store all exports with date stamps in the evidence repository.

Phase 6 — Operate: run the control set over time

Step 15 — Operationalize the recurring loop

1. Schedule `HIPAACOMP-Validation.ps1` (per-device PASS/FAIL) and `HIPAACOMP-Report.ps1` on a recurring cadence; deposit output in the evidence store.

2. Review noncompliant devices and remediate (re-evaluate via `HIPAACOMP-Remediation.ps1` in `-WhatIf` first, then `-Apply` for a named device).

3. Advance the *Minimum OS version* in the compliance policy as Windows builds progress (keeps the patch-currency bar current).

4. Review TVM exceptions at expiry and reassess exposure each period; update the control mapping (Step 2) on any change, gated by change control (R12).

5. Re-run `HIPAACOMP-Discovery.ps1` periodically to detect drift in tenant readiness (policies present, Defender onboarding, CA gate, BitLocker state).

Done means: *clinical endpoints evaluate Compliant against the enforced baselines, the CA gate blocks non-compliant devices, TVM exposure trends down, and dated evidence is retained in the repository — all traceable through the control mapping to a named owner.*

5. Testing & Validation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Validate the solution against explicit gates. Each gate has a **Test**, an **Expected result**, and **Evidence** to capture. A gate is **PASS** only when the expected result is observed and evidence is stored in the repository (R11). Run gates after each phase and again as a full pass before declaring the solution operational. Use the supplied scripts where noted; all default to read-only.

> *Testing proves the **technical controls** operate and produce evidence. It is not a HIPAA audit or a HITRUST assessment.*

Gate 1 — Tenant readiness (Assess/Configure prerequisites)

• **Test:** Run `HIPAACOMP-Discovery.ps1`. Confirm the named compliance policy and configuration baselines exist and are assigned to `HIPAA – Clinical Endpoints`; Defender for Endpoint onboarding is active; the CA gate exists; BitLocker policy is present.

• **Expected:** Discovery reports all named objects present and assigned; Defender connector healthy; `Require Compliance – Clinical Endpoints – Gate` found; no missing prerequisites.

• **Evidence:** Discovery output (console/CSV) stored with date.

Gate 2 — Devices evaluate Compliant

• **Test:** On enrolled clinical endpoints, force a sync (Settings > Accounts > Access work or school > Info > Sync) and wait an evaluation cycle. In **Intune admin center** > **Devices** > **Compliance** > `HIPAA Compliance – Clinical Endpoints – Policy` > **Device status**, review state. Run `HIPAACOMP-Validation.ps1` per device.

• **Expected:** Target clinical endpoints report **Compliant**; validation returns **PASS** for each in-scope device (any FAIL identifies a real gap to remediate).

• **Evidence:** Intune compliance export + validation PASS/FAIL output.

Gate 3 — Conditional Access blocks non-compliant devices

• **Test:** From a deliberately non-compliant clinical Windows device (e.g. BitLocker temporarily suspended in a test, or a freshly enrolled device not yet compliant), attempt to access a gated resource. Then repeat from a compliant device. Confirm via **Entra** > **Monitoring** > **Sign-in logs** > **Conditional Access** tab for `Require Compliance – Clinical Endpoints – Gate`.

• **Expected:** Non-compliant device is **blocked** (access denied, policy applied = Failure/Not satisfied); compliant device is **allowed** (Success). Break-glass account is unaffected.

• **Evidence:** Sign-in log entries (both outcomes) exported; screenshot of the block.

Gate 4 — Key safeguards enforced

Verify each safeguard is actually enforced on a sample device (not merely measured):

• **BitLocker / encryption:** `manage-bde -status` shows the OS volume **Fully Encrypted**; recovery key escrowed (Intune > device > Recovery keys). **Expected:** encrypted + key present.

• **Automatic lock / timeout:** device locks after the configured inactivity period (15 min). **Expected:** screen locks, password required on resume.

• **Antivirus (Defender):** `Get-MpComputerStatus` shows *RealTimeProtectionEnabled = True*, *AntivirusSignatureAge* low, cloud protection on. **Expected:** real-time on, signatures current.

• **Firewall:** `Get-NetFirewallProfile` shows **Enabled = True** for Domain/Private/Public. **Expected:** all profiles enabled.

• **Patch currency:** device build ≥ the compliance policy *Minimum OS version*. **Expected:** at/above the bar.

• **Evidence:** command output / config report per safeguard, captured by `HIPAACOMP-Validation.ps1` and stored.

Gate 5 — TVM exposure reduced

• **Test:** Compare the current **Exposure score** for the clinical device group in **Defender portal** > **Vulnerability management** > **Dashboard** against the Step 10 baseline after remediation tasks (`Vulnerability – Clinical Endpoints – Remediation`) and patching have run. Run `HIPAACOMP-Report.ps1` to capture exposure.

• **Expected:** Exposure score **lower** than baseline (or top recommendations closed); open remediation tasks trending down; documented exceptions only.

• **Evidence:** Dashboard export (baseline vs current), remediation/exception status, report CSV.

Gate 6 — Evidence produced and retained

• **Test:** Run `HIPAACOMP-Report.ps1` and confirm a consolidated CSV (per-device compliance, safeguard status, TVM exposure) is written to the evidence repository; confirm Intune/Defender exports are date-stamped and retained.

• **Expected:** Complete, dated evidence set present in the access-controlled repository; contents are configuration/compliance metadata only (no ePHI, per GR6).

• **Evidence:** The report file itself + repository listing showing retention.

Regression / ongoing validation

• Re-run **Gate 1** (Discovery) periodically to catch drift (deleted/unassigned policy, Defender connector failure, CA gate disabled).

• Re-run **Gate 2/4** (Validation) on the recurring cadence; investigate any new FAIL.

• Re-run **Gate 5** each period to confirm exposure stays controlled; re-run **Gate 3** after any CA change.

• For remediation actions, always run `HIPAACOMP-Remediation.ps1` in default `-WhatIf` mode and review the planned action before `-Apply`.

A full PASS across Gates 1–6 with stored evidence is the bar for "operational." Re-test after any change to a named object, gated by change control (R12).

6. Troubleshooting — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Common failure modes across the six phases, with likely cause and fix. Run `HIPAACOMP-Discovery.ps1` first when in doubt — it surfaces most readiness gaps. All diagnostic actions are read-only; remediate through the named objects, not by hand.

*These fix the **technical controls**. They are not a substitute for the organizational elements of a HIPAA/HITRUST program.*

Compliance evaluation

Devices show "Not evaluated" or no compliance state

- *Cause:* Device hasn't synced, isn't enrolled, or the policy isn't assigned to `HIPAA – Clinical Endpoints`.
- *Fix:* Confirm enrollment (**Devices** > device > overview); force sync (Settings > Accounts > Access work or school > Sync); confirm `HIPAA Compliance – Clinical Endpoints – Policy` assignment includes the group and the device is a group member. Allow an evaluation cycle.

Device unexpectedly Noncompliant

- *Cause:* A measured safeguard isn't enforced (e.g. compliance policy requires BitLocker but the `Encryption – Clinical Endpoints – Baseline` didn't apply), or a setting genuinely fails.
- *Fix:* Open the policy > **Device status** > device > **Per-setting status** to see the failing setting. Verify the matching configuration baseline is assigned and applied (**Endpoint security** / **Configuration** > policy > device status). Run `HIPAACOMP-Validation.ps1` to pinpoint the safeguard.

Compliance and configuration disagree

- *Cause:* Policy measures a setting no baseline enforces.
- *Fix:* Add/repair the enforcing baseline (implementation Steps 4–8); every measured setting needs a matching baseline.

BitLocker / encryption

BitLocker not encrypting; device fails the encryption check

- *Cause:* No usable TPM, Secure Boot disabled, or the device waiting on user action.
- *Fix:* `manage-bde -status` and check TPM (`tpm.msc`); enable/clear TPM and Secure Boot in firmware (R6). Confirm `Encryption – Clinical Endpoints – Baseline` is assigned. For hardware without a TPM, replace it — the control can't be enforced otherwise.

Recovery keys not escrowed

- *Cause:* Baseline not set to save recovery info to Entra ID before enabling.

• *Fix:* In `Encryption – Clinical Endpoints – Baseline`, set *Save BitLocker recovery information to Azure AD* = **Yes** and *Store recovery information before enabling* = **Yes**; re-sync. Verify under **Devices** > device > **Recovery keys**.

Automatic lock / antivirus / firewall

Screen doesn't lock on timeout

• *Cause:* `Lock – Clinical Endpoints – Baseline` not applied or overridden.

• *Fix:* Confirm the settings-catalog policy is assigned/applied; check for a conflicting policy in per-setting status; verify *Maximum Inactivity Time Lock Screen* / machine inactivity limit values.

Defender AV reported unhealthy / signatures stale

• *Cause:* Cloud/real-time protection off, signature update blocked, or a third-party AV present.

• *Fix:* `Get-MpComputerStatus`; ensure `Antivirus – Clinical Endpoints – Baseline` enables real-time + cloud protection and a short signature interval. Remove/disable conflicting third-party AV (Defender goes passive when another AV is active). Confirm connectivity to update endpoints (GR5).

Firewall check fails

• *Cause:* A profile disabled or overridden by GPO/third-party.

• *Fix:* `Get-NetFirewallProfile`; confirm `Firewall – Clinical Endpoints – Baseline` enables all three profiles; resolve GPO/third-party conflicts.

Conditional Access (the gate)

Compliant users still blocked

• *Cause:* Device not Entra-registered/compliant at token time, or policy scoped too broadly.

• *Fix:* Confirm the device is compliant **and** Entra-joined/registered; review **Sign-in logs** > **Conditional Access** for which control failed. Re-check the policy's device platform condition and grant control.

Admins locked out / risk of lockout

• *Cause:* No break-glass exclusion, or gate enabled before report-only validation.

• *Fix:* Use the excluded break-glass account (R8) to regain access; set the gate to **Report-only**, validate impact, then enable. Always keep break-glass excluded.

Non-compliant device NOT blocked

• *Cause:* Gate still in Report-only, or device/user outside scope.

• *Fix:* Confirm `Require Compliance – Clinical Endpoints – Gate` is **On**, the user is in the included population, and the device platform/target resource match.

Defender Vulnerability Management

No exposure data / devices missing from TVM

• *Cause:* Devices not onboarded to Defender for Endpoint, or sensor inactive.

• *Fix:* **Defender portal** > **Assets** > **Devices** — confirm Onboarded + Active sensor (R4). Re-deploy onboarding via the Intune connector; confirm connectivity (GR5).

Remediation task created but exposure unchanged

• *Cause:* Patch/config not actually deployed, or recommendation needs the baseline/Update ring.

• *Fix:* Close patch findings via `Patch – Clinical Endpoints – Baseline` (Update ring); close config findings via the matching baseline. Manual fixes drift back — enforce via policy.

Recommendation can't be remediated (medical/vendor device)

• *Cause:* Embedded/unpatchable clinical device.

• *Fix:* Create a Defender **exception** with justification, owner approval (R10), and expiry; record in the evidence store (R12); compensate with network segmentation.

Evidence / reporting

Report script returns nothing or errors on auth

• *Cause:* Missing Microsoft Graph scopes/modules or insufficient role.

• *Fix:* Ensure the Microsoft Graph PowerShell SDK is installed and the operator has read access to Intune/Defender data; connect with the required read scopes (the script header lists them). Re-run.

Evidence missing for a past period

• *Cause:* Reports not scheduled/retained.

• *Fix:* Schedule `HIPAACOMP-Report.ps1` / `HIPAACOMP-Validation.ps1` on a cadence; write to the retained, access-controlled repository (R11) with retention applied. You cannot reconstruct past-period evidence after the fact.

Concern: ePHI in evidence

• *Cause:* Report scope too broad.

• *Fix:* Confirm outputs are device/compliance/exposure metadata only (GR6); redact any incidental sensitive values; restrict the repository.

Discovery / drift

Discovery flags a missing named object

• *Cause:* Object deleted, renamed off-convention, or unassigned.

• *Fix:* Recreate/rename to the exact `<Purpose> – <Scope> – <Stage>` name and reassign to `HIPAA – Clinical Endpoints`; update the control mapping under change control (R12).

7. Best Practices — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

Operational guidance for running the control set well, surviving an audit, and avoiding the failure modes that turn a good baseline into a false sense of security.

*Reminder: these practices strengthen the **technical enforcement and evidence**. Compliance and certification also require organizational policy, risk analysis, training, BAAs, physical safeguards, and (for HITRUST) authorized assessment.*

Naming and traceability

• **Use the** `<Purpose> – <Scope> – <Stage>` **names verbatim** across Intune, Defender, the CA gate, scripts, and evidence (`Encryption – Clinical Endpoints – Baseline`, `Require Compliance – Clinical Endpoints – Gate`, etc.). Consistent names let an assessor trace control → object → evidence in seconds.

• **One scope group, named once.** Assign every object to `HIPAA – Clinical Endpoints`. Avoid per-policy ad hoc groups — divergent scope is the most common silent gap.

• **Keep the control mapping current.** Treat it as a living artifact; update it whenever an object is created, renamed, or retired, under change control.

Compliance policy design

• **Measure what you enforce.** Every setting in the compliance policy must have a matching configuration baseline that enforces it. A policy that *measures* BitLocker without a baseline that *deploys* it just reports failure.

• **Advance the patch bar deliberately.** Raise *Minimum OS version* on a schedule as Windows builds progress; pair with the Update ring so devices can actually meet the bar before it rises.

• **Set a grace/action period thoughtfully.** Immediate non-compliance marking is honest for audit but can be disruptive; pair with a user notification so clinicians know how to self-remediate.

• **Use Defender machine risk as a compliance signal** (risk score condition) so an actively compromised device falls out of compliance and is gated.

Conditional Access (the gate)

• **Always roll out in Report-only first**, review impact in sign-in logs, then enable. A misconfigured gate can lock clinicians out of the EHR.

• **Keep a tested break-glass account** excluded from all CA policies, with monitored sign-ins and a securely stored credential. Test it before you need it.

• **Scope the gate to the resources that hold ePHI** where possible, rather than all apps, to minimize collateral lockout while still protecting sensitive data.

• **Account for shared/kiosk clinical workstations** explicitly — confirm the gate behaves correctly with shared sign-in patterns.

Vulnerability management (Defender TVM)

• **Prioritize by exposure, not count.** Close the few recommendations that drive most of the exposure score first; don't chase a long tail.

• **Close patch findings with the Update ring, config findings with baselines.** Don't remediate by hand what a policy should enforce — manual fixes drift back.

- **Govern exceptions strictly.** Every exception needs a justification, an owner approval (R10), and an expiry. Medical-device and vendor-locked software are legitimate but must be time-bound and reviewed, not permanent.
- **Watch clinical/medical devices.** Many run unpatchable embedded OSes; isolate or compensate (network segmentation) rather than silently accepting risk on the general baseline.

Evidence and audit readiness

- **Automate evidence on a cadence.** Schedule `HIPAACOMP-Report.ps1` and `HIPAACOMP-Validation.ps1`; date-stamp output. Evidence you have to scramble to produce mid-audit looks like evidence you don't keep.
- **Retain for the look-back period.** HIPAA documentation retention is six years; keep dated exports for the full window in the access-controlled repository.
- **Never put ePHI in evidence.** Reports capture device/compliance/exposure metadata only (GR6). The evidence store must not become a new breach surface.
- **Keep baseline vs current exposure** so you can demonstrate trend (improvement) over the period, which assessors value more than a single snapshot.

Operations and change control

- **Pilot before broad rollout.** Apply new/changed objects to a small pilot subset of `HIPAA – Clinical Endpoints` first, validate, then expand.
- **Gate changes through the owner.** Changes to compliance settings, the CA gate, and exceptions go through the change/exception process (R12) with approval and a record.
- **Reconcile baseline conflicts.** If you apply a Microsoft Security baseline alongside targeted baselines, check for and resolve conflicting settings (Intune flags conflicts in per-setting status).
- **Use Microsoft Purview Compliance Manager** as an optional aid to track improvement actions against a HIPAA/HITRUST template — but treat its score as guidance, not certification.

Least privilege and identity hygiene

- **Scope admin roles** (Intune Administrator, Security Administrator, Conditional Access Administrator) rather than Global Administrator; make privileged roles PIM-eligible where licensed.
- **Enforce MFA for all admins** and ideally all users — credential theft remains the leading healthcare breach cause.

8. Deliverables Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender)

This solution ships as a documentation set plus a script toolkit. Together they let an administrator map the controls, build and gate the enforcement, remediate vulnerabilities, and produce audit-ready evidence on clinical Windows endpoints.

*The deliverables provide **technical enforcement and evidence**. They do not constitute HIPAA compliance or HITRUST certification — those require organizational policy, risk analysis, training, BAAs, physical safeguards, and authorized assessment.*

Documentation

#	Document	Purpose
1	**Solution Overview** (`01-solution-overview.md`)	What the solution does, scope, outcomes, audience, and the framework-not-certification boundary.
2	**Requirements** (`02-requirements.md`)	Solution-specific prerequisites R1–R12 (licensing, Defender onboarding, Entra ID P1, BitLocker hardware, the `HIPAA – Clinical Endpoints` group, control mapping/owner, evidence store, change control) with verify/implement steps.
3	**Global Requirements — Healthcare Solutions** (`global-requirements-healthcare-solutions.md`)	Category-wide tenant/identity/network/data-handling baseline (GR1–GR9).
4	**Implementation** (`03-implementation.md`)	Phase-by-phase build (Assess → Configure → Gate → Remediate → Evidence → Operate) with full navigation paths and named objects.
5	**Testing & Validation** (`05-testing.md`)	Gates 1–6 (Compliant, CA blocks, safeguards enforced, exposure reduced, evidence produced) with expected results and evidence.
6	**Best Practices** (`07-best-practices.md`)	Operational guidance: naming/traceability, policy design, CA rollout, TVM, evidence, change control.
7	**Troubleshooting** (`06-troubleshooting.md`)	Common failure modes and fixes across compliance, CA, Defender, and evidence.
8	**Executive Summary** (`executive-summary.md`)	Business-level summary for decision-makers.

Scripts (PowerShell, Microsoft Graph where applicable)

All scripts use the `HIPAACOMP-` prefix, carry a header block, and default to read-only. `.NOTES` is neutral: *Healthcare Solutions — read-only.*

#	Script	What it does
1	`HIPAACOMP-Discovery.ps1`	Tenant readiness: confirms the named compliance policy + configuration baselines, Defender for Endpoint onboarding, the Conditional Access gate, and BitLocker state. Read-only.
2	`HIPAACOMP-Validation.ps1`	Per-device validation: compliant, BitLocker on, Defender healthy, key settings (lock/AV/firewall/patch) enforced. Emits **PASS/FAIL**. Read-only.
3	`HIPAACOMP-Report.ps1`	Consolidated audit evidence: compliance state + Defender TVM exposure + safeguard status, exported to **CSV** for the evidence repository. Read-only.
4	`HIPAACOMP-Remediation.ps1`	Safe remediation: re-evaluates compliance / triggers remediation for a **named device**. Defaults to read-only `-WhatIf`; acts only with `-Apply`.
5	`HIPAACOMP-Set-ComplianceBaseline.ps1`	Scaffolds the compliance policy and the Conditional Access gate (named objects). Supports `-WhatIf` to preview before creating.

Visual asset

- `HIPAACOMP-hero.png` — hero image for the solution listing.

How the deliverables fit together

1. Read the **Requirements** and **Global Requirements**; close gaps.
2. Run `HIPAACOMP-Discovery.ps1` to baseline tenant readiness.

3. Follow the **Implementation** to build the named compliance policy, configuration baselines, and CA gate (optionally scaffold with `HIPAACOMP-Set-ComplianceBaseline.ps1 -WhatIf` first), then run the Defender TVM remediation workflow.

4. Validate with the **Testing** gates using `HIPAACOMP-Validation.ps1`.

5. Produce evidence with `HIPAACOMP-Report.ps1`; remediate drift with `HIPAACOMP-Remediation.ps1` (`-WhatIf` then `-Apply`).

6. Operate continuously per **Best Practices**, using **Troubleshooting** as needed.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

HIPAACOMP-Discovery.ps1

HIPAACOMP-Remediation.ps1

HIPAACOMP-Report.ps1

HIPAACOMP-Set-ComplianceBaseline.ps1

HIPAACOMP-Validation.ps1